B01 — Kebijakan & prosedur SBOM

© 2026 Dea Saka Kurnia Putra. All rights reserved.

Kontrol dokumen	
ID dokumen	B01
Judul	Kebijakan & prosedur SBOM
Versi	0.1.0 (= versi aplikasi) · commit `4a4a942`
Tanggal	2026-10-23
Status	Draf
Klasifikasi	Publik
Pemilik	Dea Saka Kurnia Putra
Penyusun	Dibangkitkan oleh `scripts/compliance/*` (Claude Code) dari sumber kebenaran repo
Penyetuju	[KONFIRMASI] — penyetuju dokumen belum ditetapkan
Lingkup	Semua artefak rilis Finandex dan SBOM-nya
Standar acuan	CISA 2026 Minimum Elements for a Software Bill of Materials (29 Juli 2026); CycloneDX 1.7 (ECMA-424 edisi ke-2); SPDX 2.3; ISO/IEC 5230:2020 (OpenChain lisensi); ISO/IEC 18974:2023 (OpenChain keamanan); NIST SP 800-218 (SSDF)
Dokumen terkait	B02, B03, B04, B05

Riwayat perubahan

Versi	Tanggal	Perubahan
0.1.0	2026-10-23	Versi pertama, dibangkitkan dari artefak SBOM rilis ini.

1. Tujuan

Setiap rilis Finandex disertai *Software Bill of Materials* (SBOM) yang dapat diproses mesin, ditandatangani, beratestasi, dan disertai pernyataan VEX, agar penerima dapat menilai komponen, lisensi, dan kerentanan perangkat lunak secara mandiri.

2. Cakupan — satu SBOM per artefak + SBOM induk

Artefak	File	Komponen	Skor sbomqs
Web/PWA, fungsi serverless `api/index.mjs`, lapisan web Capacitor — dependensi npm produksi	`finandex-0.1.0-web.cdx.json`	252	9.2
Aplikasi Android (Capacitor 8) — dependensi Gradle + modul plugin	`finandex-0.1.0-android.cdx.json`	16	8.3
Aplikasi iOS/iPadOS (Capacitor 8) — Swift Package Manager	`finandex-0.1.0-ios.cdx.json`	11	8.5
Desktop macOS/Windows (Tauri 2) — belum ada biner di rilis ini	`finandex-0.1.0-desktop.cdx.json`	0	4.7
42 dataset input, dataset kit, PDF regulasi terverifikasi, font OFL, ikon	`finandex-0.1.0-data.cdx.json`	114	6.8
Implementasi referensi Python (hanya CI paritas; tidak didistribusikan)	`finandex-0.1.0-python-reference.cdx.json`	3	6.8
Alat build & uji (devDependencies npm; tidak didistribusikan)	`finandex-0.1.0-tooling.cdx.json`	1.144	9.2

SBOM induk `finandex-0.1.0.cdx.json`: 1.549 komponen (hierarkis: satu komponen per artefak, masing-masing berisi komponennya sendiri dan menautkan file SBOM-nya lewat `bom-link`), 7 layanan eksternal (`services[]`) dan 2 model AI (`machine-learning-model`, lihat B05). Skor sbomqs: **9.0**.

Cakupan mencakup semua dependensi transitif tanpa batas kedalaman. Lockfile berisi 1.523 paket (262 produksi, 1.261 dev); paket opsional khusus platform yang tidak terpasang di mesin pembangkit dicatat sebagai *known unknown* di `metadata.properties`.

3. Format

- **Utama:** CycloneDX **1.7** JSON (ECMA-424 edisi ke-2), divalidasi terhadap skema JSON resmi.
- **Sekunder:** SPDX **2.3** JSON (`finandex-0.1.0-web.spdx.json`) untuk interoperabilitas. Catatan: ISO/IEC 5962:2021 menstandarkan SPDX 2.2.1; SPDX 3.0.1 akan ditambahkan bila alat pembangkitnya stabil.
- Lisensi data dokumen SBOM: **CC0-1.0** (`metadata.licenses`).

4. Elemen minimum (CISA 2026) dan pemetaannya

Elemen CISA 2026	CycloneDX 1.7	SPDX 2.3	Diuji otomatis
SBOM Author	`metadata.authors[]`	`creationInfo.creators` (Person:)	ya
SBOM Author Signature	bundel Sigstore `*.sigstore.json` + atestasi GitHub	idem	CI (compliance.yml)
SBOM Data Format Name / Version	`bomFormat` / `specVersion`	`spdxVersion`	ya
SBOM Generation Context	`metadata.lifecycles[].phase`	`creationInfo.comment`	ya
SBOM Tool Name / Version	`metadata.tools.components[]`	`creationInfo.creators` (Tool:)	ya

© 2026 Dea Saka Kurnia Putra. All rights reserved. — Finandex

Elemen CISA 2026	CycloneDX 1.7	SPDX 2.3	Diuji otomatis
SBOM Version	`version` + `serialNumber`	`documentNamespace`	ya
SBOM Timestamp	`metadata.timestamp` (tanggal commit rilis)	`creationInfo.created`	ya
Component Name / Version	`components[].name` / `.version`	`packages[].name` / `.versionInfo`	ya
Component Producer	`components[].supplier`	`packages[].supplier`	ya
Component Identifiers	`purl`, `bom-ref`	`externalRefs` (purl)	ya
Component Hash Value / Algorithm	`hashes[]` (SHA-512 dari lockfile, SHA-256 untuk data)	`checksums[]`	ya (atau *known unknown* tertulis)
Component License	`licenses[]` (declared + concluded)	`licenseDeclared` / `licenseConcluded`	ya
Component Dependency Relationship	`dependencies[]`	`relationships[]`	ya
Coverage	seluruh komponen transitif; `compositions[].aggregate`	—	ya (selisih lockfile = 0 atau *known unknown*)
Distribution and Delivery, Frequency	proses di dokumen ini (§6)	proses	—

Hasil pemeriksaan terakhir: **156 pemeriksaan, 0 gagal** (`docs/compliance/sbom/SBOM_CHECK.json`, dibangkitkan oleh scripts/compliance/check-sbom-min-elements.ts @ 4a4a942).

5. Informasi yang tidak diketahui (*known unknowns*)

Informasi yang tidak diketahui dinyatakan eksplisit dan dibedakan dari yang sengaja dirahasiakan (Finandex tidak merahasiakan komponen apa pun):

- hash dependensi Maven/SPM yang diselesaikan alat build platform saat build (`finandex:hash`);
- versi paket Python referensi yang tidak dipin di `parity.yml`;
- paket npm opsional khusus sistem operasi lain;
- digest artefak rilis (diikat oleh atestasi *build provenance*);
- biner desktop Tauri (belum ada di rilis ini).

Pertanyaan tentang SBOM: kontak keamanan di `SECURITY.md` / `/legal/security` (**[KONFIRMASI]** alamat kontak).

6. Pembuatan, frekuensi, distribusi, retensi

1. `npm run sbom:generate` → `npm run sbom:verify` (gate) di setiap rilis (tag `v*`) melalui `.github/workflows/compliance.yml`, dan setiap kali informasi komponen berubah (lockfile, Gradle, SPM, dataset, regulasi).
2. Penandatanganan Sigstore *keyless* (OIDC GitHub Actions) + atestasi SBOM dan *build provenance* GitHub (setara SLSA Build).
3. Distribusi: aset GitHub Release `v<versi>` dan halaman publik **/legal/sbom** (file di `/sbom/<versi>/`, daftar di `/sbom/index.json`).
4. Retensi: SBOM semua versi yang pernah dirilis tetap tersedia di GitHub Releases.

© 2026 Dea Saka Kurnia Putra. All rights reserved. — Finandex

7. Kualitas

Gate: semua elemen §4 ada, skema valid, `sbomqs` SBOM induk ≥ 8,0 (terukur: **9.0**), tidak ada kebocoran path lokal / nama pengguna / token / URL internal. Skor rendah pada SBOM data (6.8) disebabkan lisensi dataset yang bukan pengenal SPDX (dicantumkan apa adanya dari penyedia), dan pada SBOM desktop (4.7) karena belum ada biner.

English summary

Every Finandex release ships machine-readable SBOMs: one per artefact (web/PWA & serverless, Android, iOS, desktop, data & assets, Python reference, build tooling) plus a hierarchical master SBOM with external services and AI models. Primary format **CycloneDX 1.7** (ECMA-424, 2nd ed.), secondary **SPDX 2.3**. All **CISA 2026 minimum elements** are checked automatically (156 checks, 0 failed); master SBOM sbomqs score **9.0/10**. SBOMs are signed with Sigstore (keyless) and attested with GitHub artifact attestations at release, with a CycloneDX **VEX** document for every scanner finding. Download them at **/legal/sbom** or from the GitHub Release; see B02 for verification commands.

© 2026 Dea Saka Kurnia Putra. All rights reserved. — Finandex